



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

COMENTÁRIOS DO GESTOR

GSI - Gabinete de Segurança Institucional do Estado do Rio de Janeiro

1. Introdução

Este documento orienta a manifestação da **GSI** na fase de comentários do gestor. Conforme o caso, a manifestação poderá tratar dos achados e situações de inadequação registrados no Relatório Individual Preliminar, dos itens avaliados como não conformes na etapa de avaliação das evidências ou da ausência de resposta válida ao questionário iGovTI 2026.

A manifestação deve ser apresentada no questionário eletrônico de comentários do gestor, observando-se apenas as seções disponibilizadas para a organização.

Quando houver achados, a organização deverá informar se concorda ou discorda de cada situação apontada e, quando couber, apresentar comentários, justificativas e documentação comprobatória. Nas questões-base indicadas na seção de reavaliação de evidências, a organização poderá apresentar esclarecimentos, retificações ou evidência suplementar para reanálise dos itens avaliados como não conformes. Quando não houver resposta válida ao questionário iGovTI 2026, a manifestação deverá se limitar a esclarecimentos, comprovação de eventual envio anterior ou justificativa para a ausência de resposta.

A etapa de comentários do gestor é desejável, mas tem caráter opcional para a organização auditada. Sua finalidade é permitir que o gestor apresente esclarecimentos sobre fatos, retifique informações, informe providências adotadas ou planejadas e encaminhe documentação complementar pertinente.

Considerando a natureza da solicitação, relativa aos comentários dos gestores sobre achados de auditoria, o prazo para finalização e envio do questionário é **improrrogável**, conforme o item 8.4 do Manual de Auditoria do TCE-RJ, e se encerra em **10/07/2026**.

Recomenda-se que o questionário seja preenchido com antecedência. Eventuais solicitações de esclarecimento poderão ser encaminhadas para o e-mail **auditoriati@tcerj.tc.br**.

Achado 1 – Estrutura de TIC insuficiente para coordenar, gerir e sustentar a tecnologia da informação.

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **GSI** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “Área de TIC sem atribuições formais suficientes para planejamento, coordenação, gestão, execução, monitoramento e controle da TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 2 – Governança de TIC insuficiente para avaliar, dirigir e monitorar a tecnologia da informação.

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **GSI** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“Modelo básico de governança e gestão de TIC inexistente ou insuficiente quanto a papéis, responsabilidades, objetivos, indicadores, metas ou acompanhamento.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Comitê de TIC ou instância equivalente não instituído formalmente.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 3 – Planejamento de TIC insuficiente para orientar a gestão, o orçamento e as contratações de TIC

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **GSI** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “**Plano de TIC sem vínculo demonstrado com orçamento e contratações de TIC**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **GSI** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“A organização não definiu o quantitativo necessário de pessoal de TIC e segurança da informação.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Ausência de cargos, funções, perfis ou ocupações específicas de TIC e segurança da informação.”** apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Perfis profissionais de TIC e segurança da informação inexistentes, insuficientes ou não utilizados na escolha de gestores.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Lacunas de competências dos colaboradores e gestores de TIC e segurança da informação não são identificadas ou tratadas.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **GSI** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “**Inexistência ou insuficiência do catálogo de serviços de TIC.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Ausência ou fragilidade na definição e no monitoramento de níveis mínimos de serviço de TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Inexistência ou fragilidade do inventário de ativos de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Ausência ou fragilidade do processo de gestão de configuração.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **GSI** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “**Contratações de TIC sem análise prévia e aprovação técnica obrigatória da área de TIC.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Contratações de TIC sem alinhamento demonstrado ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária.” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



Reavaliação de evidências

Esta seção permite que a organização apresente comentários, esclarecimentos, retificações ou evidência suplementar para reavaliação de questões que tiveram pelo menos um item ou subitem classificado como não conforme na etapa de avaliação das evidências.

Consulte no Relatório Individual Preliminar e nos anexos correspondentes os itens específicos avaliados como não conformes. A apresentação de nova evidência é opcional e deve se limitar a arquivo em formato PDF ou ZIP.



Questão 1001. A alta administração estabeleceu modelo de gestão de tecnologia da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q1001 - d) a organização designa responsáveis de cada área de negócio para a gestão dos respectivos sistemas informatizados
Resposta informada pelo auditado	Sim
Avaliação	Não foi apresentada evidência da designação formal de gestores de sistemas para cada área de negócio. Embora o documento defina a estrutura central da TI, não há ato ou registro que atribua responsabilidades de gestão de sistemas específicos aos representantes das áreas finalísticas. A evidência é insuficiente por não identificar a responsabilidade descentralizada dessas áreas.
Item avaliado	Q1001 - e) a organização dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização
Resposta informada pelo auditado	Sim
Avaliação	Embora o documento mencione uma 'equipe de elaboração' ou 'comitê', a composição evidenciada é restrita aos integrantes da divisão de TI. Não foram apresentados os atos constitutivos ou registros que comprovem a participação de representantes das demais áreas relevantes da organização no referido comitê. A evidência é insuficiente para demonstrar a representatividade multisetorial necessária.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2102. A organização possui plano de tecnologia da informação vigente.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2102 - b) o plano de TI é publicado na internet, para fácil acesso de partes interessadas e da sociedade
Resposta informada pelo auditado	Sim
Avaliação	Embora o documento mencione na página 5 a intenção de publicação nos sites oficiais, não foram apresentados elementos que comprovem a efetiva publicação na internet. Não constam nos autos capturas de tela, links ativos ou registros públicos que demonstrem o acesso ao plano pela sociedade. A ausência de comprovação de publicidade impede o atendimento ao critério de transparência.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2203. A organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação).

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2203 - A organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação).
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A gestão de configuração e ativos de TI não está implementada de forma evidenciável. O documento '00086_09_glpi-3.pdf' lista apenas projetos e tarefas de gerenciamento com status de execução, sem representar um inventário de ativos ou base de dados de configuração (CMDB). A evidência é insuficiente por não apresentar normas, procedimentos ou registros operacionais de gestão de ativos. As lacunas incluem a ausência de política formal e de qualquer inventário técnico de ativos.
Item avaliado	Q2203 - a) a organização mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles
Resposta informada pelo auditado	Sim
Avaliação	Não foi comprovada a manutenção de base de dados consolidada com ativos e relacionamentos técnicos. O relatório '00086_09_glpi-3.pdf' contém apenas registros de projetos que não exibem atributos de configuração, criticidade ou topologia. A evidência é insuficiente por não demonstrar a existência de CMDB ou estrutura de dados vinculada aos ativos. A lacuna principal é a inexistência de inventário técnico de ativos e serviços com seus devidos relacionamentos.
Item avaliado	Q2203 - b) a base de dados de configurações é utilizada como insumo para o planejamento e o acompanhamento das mudanças
Resposta informada pelo auditado	Sim
Avaliação	Não há evidência de que a base de dados de configurações seja utilizada para apoiar processos de mudança. O documento '00086_09_glpi-3.pdf' foca no acompanhamento de projetos e não apresenta registros de mudanças integrados a itens de configuração. A evidência é insuficiente, pois não conecta a ferramenta citada ao planejamento ou acompanhamento de mudanças com avaliação de impacto. A lacuna relevante é a ausência de histórico de mudanças que demonstre integração com a gestão de configuração.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

--



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2204. A organização executa processo(s) de gestão de incidentes de serviços de tecnologia da informação e de incidentes de segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2204 - c) há base(s) de conhecimento que registra(m) erros conhecidos e problemas, de modo a tornar eficiente e efetiva a resolução de incidentes
Resposta informada pelo auditado	Sim
Avaliação	Não há evidência da existência de uma base de conhecimento estruturada destinada especificamente ao registro de erros conhecidos e problemas (KEDB). Embora os documentos apresentem playbooks de resposta, estes possuem natureza operacional de procedimento, não constituindo um repositório de erros e problemas recorrentes. A ausência deste elemento de consulta impede a verificação da eficiência na resolução de incidentes conforme exigido pelo critério.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2501. A organização executa processo de gestão de ativos associados à informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2501 - c) o inventário identifica as informações críticas que os ativos armazenam, processam ou transmitem
Resposta informada pelo auditado	Sim
Avaliação	O item não está conforme. O documento apresentado foca no registro de atributos técnicos dos ativos, como número de série e especificações, sem contemplar a identificação da criticidade das informações associadas aos ativos no inventário. A evidência é insuficiente para atender ao requisito, pois a menção a dados críticos restringe-se ao planejamento de backup e não à gestão do inventário. Existe a lacuna de um campo ou registro que vincule o ativo à criticidade da informação armazenada ou processada.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2504. A organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2504 - A organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A organização apresentou apenas um relatório de status de projetos de TI, o qual não constitui evidência de execução efetiva de controles ou procedimentos de gestão da segurança. Não há registros de operação contínua, documentação de gestão, monitoramento de segurança ou qualquer menção a recursos de computação em nuvem. A evidência é insuficiente por se tratar de um demonstrativo de planejamento e não de documentos comprobatórios da operacionalização da segurança.
Item avaliado	Q2504 - a) a organização gerencia (inventaria e controla) os dispositivos conectados em sua rede
Resposta informada pelo auditado	Sim
Avaliação	Não foi apresentado inventário consolidado ou relatório de controle de dispositivos conectados à rede. O documento fornecido lista projetos de aquisição de equipamentos, o que não equivale a uma ferramenta de inventário operacional e atualizado. Falta a apresentação do inventário de hardware com os respectivos controles de identificação.
Item avaliado	Q2504 - b) a organização gerencia (inventaria e controla) os softwares instalados nos dispositivos conectados em sua rede
Resposta informada pelo auditado	Sim
Avaliação	Não houve apresentação de evidência de inventário de softwares instalados. O relatório de projetos não contém informações sobre o controle de licenças ou relação de softwares em uso nos dispositivos. Falta documento que comprove o inventário e controle de softwares.
Item avaliado	Q2504 - c) a organização gerencia vulnerabilidades técnicas em seus ativos de software, de hardware e de rede críticos para o negócio
Resposta informada pelo auditado	Sim
Avaliação	Embora o relatório mencione projetos de hardening, não há evidências de processos operacionais de gestão de vulnerabilidades. Inexistem registros de scans, relatórios de

vulnerabilidades identificadas ou cronogramas de remediação. Faltam evidências de execução da gestão de vulnerabilidades técnica.

Item avaliado Q2504 - d) a organização implementa configurações seguras em seus ativos de software, de hardware e de rede críticos para o negócio

Resposta informada pelo auditado Sim

Avaliação O projeto de hardening listado encontra-se em estágio inicial de execução, não comprovando a implementação efetiva de configurações seguras. Não foram apresentados padrões de configuração (baselines) ou checklists de conformidade aplicados aos ativos. Faltam registros que comprovem a configuração segura dos ativos.

Item avaliado Q2504 - e) a organização mantém, monitora e analisa logs de auditoria dos ativos de software, de hardware e de rede críticos para o negócio

Resposta informada pelo auditado Sim

Avaliação O registro de conclusão de um projeto de ferramenta de monitoramento não comprova que os logs de auditoria são efetivamente mantidos, monitorados e analisados. Não foram fornecidas amostras de logs, relatórios de análise de segurança ou procedimentos de gestão de alertas. Falta evidência de operação contínua do monitoramento e análise de logs.

Item avaliado Q2504 - f) a organização aplica controles compensatórios para o uso de privilégios administrativos em seus ativos de software, de hardware e de rede críticos para o negócio

Resposta informada pelo auditado Sim

Avaliação Não foram apresentadas evidências de controles ou procedimentos relacionados à gestão de privilégios administrativos. O documento fornecido não cita políticas, sistemas de controle de acesso ou registros de uso de contas com privilégios elevados. Faltam evidências documentais sobre controles de privilégios.

Item avaliado Q2504 - g) a organização implementa defesas contra malware (ex: vírus) e outras ameaças cibernéticas (ex: phishing)

Resposta informada pelo auditado Sim

Avaliação A simples menção a um contrato de antivírus não comprova a efetividade das defesas contra malware em operação. Não há registros de ativação das ferramentas, cobertura dos endpoints ou defesas contra phishing configuradas no ambiente. Faltam evidências operacionais de proteção contra malware.

Item avaliado Q2504 - h) a organização limita e controla o uso de portas, protocolos e serviços de rede nas conexões de sua rede interna com a internet e outras redes externas

Resposta informada pelo auditado Sim

Avaliação	A implementação de segmentação por VLANs não supre a necessidade de controle de portas e protocolos nas conexões externas. O projeto de firewall (PFSENSE) consta no relatório como não implementado (0% de execução). Faltam políticas de firewall ou regras de controle de tráfego implementadas.		
Item avaliado	Q2504 - i) a organização implementa defesa de perímetro das conexões de sua rede interna com a internet e outras redes externas		
Resposta informada pelo auditado	Sim		
Avaliação	O relatório de projetos indica que as ferramentas de firewall e defesa de perímetro estão com status 'New' (0% de execução). Não há evidência de solução de defesa de perímetro comprovadamente implementada ou operacional no ambiente. Falta a comprovação de implementação de mecanismos de defesa perimetral.		
Item avaliado	Q2504 - j) a organização implementa cópias regulares de segurança (backup) das informações em meio digital, conforme as melhores práticas e as necessidades de negócio, incluindo a realização periódica de testes de recuperação das informações		
Resposta informada pelo auditado	Sim		
Avaliação	Não foram fornecidos registros de backup, políticas de retenção ou evidências de testes de recuperação de dados. O projeto mencionado de CPD encontra-se em fase de análise, sem implementação. Faltam evidências operacionais de cópias de segurança e testes de restauração.		
Item avaliado	Q2504 - k) a organização executa regularmente testes de segurança em seu ambiente de TI (detecção de vulnerabilidades e testes de penetração)		
Resposta informada pelo auditado	Sim		
Avaliação	Não há registro de execução de testes de segurança, scans de vulnerabilidade ou testes de penetração no documento enviado. O relatório de projetos não lista atividades voltadas a testes de segurança recorrentes. Faltam relatórios de testes de segurança realizados.		

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2802. A organização executa processo de planejamento anual das contratações.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2802 - A organização executa processo de planejamento anual das contratações.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A avaliação realizada indica conformidade parcial. A publicação do Plano de Contratações Anual (PCA) no Portal Nacional de Contratações Públicas (PNCP), verificada no arquivo 00086_23_pncp-gsi.pdf, demonstra que o planejamento é executado e divulgado. Contudo, a análise revela ausência de evidências documentais essenciais quanto à aprovação formal, participação de setores, integração de planejamento e fundamento orçamentário. A suficiência da evidência é limitada ao registro de publicação, não demonstrando os processos internos de gestão necessários para a conformidade total.
Item avaliado	Q2802 - a) a alta administração (ou conselho ou colegiado superior) aprova formalmente o Plano de Contratações Anual (PCA)
Resposta informada pelo auditado	Sim
Avaliação	A avaliação indica não conformidade. Embora o PCA esteja publicado no PNCP, conforme consta no documento 00086_23_pncp-gsi.pdf, não foi apresentada evidência documental do ato de aprovação formal pela alta administração, conselho ou colegiado superior. O print do portal não supre a ausência de um documento, ato ou registro que ateste a homologação formal do plano.
Item avaliado	Q2802 - b) os setores relevantes da organização participam da elaboração do PCA
Resposta informada pelo auditado	Sim
Avaliação	A avaliação indica não conformidade. A evidência apresentada (arquivo 00086_23_pncp-gsi.pdf) limita-se à visualização do PCA no PNCP, não demonstrando o fluxo de trabalho interno ou a colaboração entre os setores da organização. Não foram disponibilizados registros que comprovem a participação das unidades na elaboração do plano.
Item avaliado	Q2802 - c) na elaboração do PCA são considerados os demais instrumentos de planejamento da organização
Resposta informada pelo auditado	Sim
Avaliação	A avaliação indica não conformidade. Não há, no arquivo 00086_23_pncp-gsi.pdf, elementos que vinculem o PCA a outros instrumentos de planejamento institucional da organização. A evidência restringe-se aos dados do portal, sem demonstrar a integração com planejamento estratégico ou documentos similares.



Item avaliado Q2802 - d) o PCA fundamenta a proposta orçamentária da organização

Resposta

informada pelo Sim

auditado

Avaliação

A avaliação indica não conformidade. O arquivo 00086_23_pncp-gsi.pdf apresenta apenas a listagem dos itens contratados no PNCP, sem estabelecer a conexão com a proposta orçamentária da organização. Não foram apresentadas evidências documentais ou orçamentárias que justifiquem esta relação.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP